AFRICA'SPY

INTELLIGENCE ACADEMY

AFS-D101 · SUPPORT DE COURS ET FICHE DE SYNTHÈSE

Renseignement numérique et OSINT avancé

Cyberespionnage, empreintes numériques et investigation sur métadonnées.

DOMAINE	Cyberespionnage et renseignement numérique
NIVEAU	Avancé
DURÉE INDICATIVE	20 heures
ÉDITION	13 novembre 2026

Document pédagogique réservé aux apprenants inscrits. Les scénarios, organisations et données cités dans les exercices et études de cas sont fictifs. AFRICA'SPY est un organisme de formation privé ; ce support ne vaut pas diplôme.

Présentation

Le numérique est devenu le principal terrain de collecte et d'affrontement informationnel. Cette formation donne aux analystes la culture technique nécessaire pour **comprendre les menaces** et **mener des investigations ouvertes rigoureuses**.

Cadre pédagogique : tous les exercices utilisent des environnements isolés, des jeux de données synthétiques fournis par l'Académie et des scénarios fictifs. Aucune technique d'intrusion n'est enseignée.

Objectifs pédagogiques	Compétences visées
• Expliquer les modes opératoires du cyberespionnage • Conduire une recherche OSINT avancée méthodique et légale • Analyser une empreinte numérique organisationnelle • Extraire et interpréter des métadonnées de fichiers • Documenter une investigation de façon reproductible	• Utiliser des opérateurs de recherche avancés • Pivoter entre indicateurs (domaine, IP, certificat) • Lire les métadonnées EXIF et documentaires • Réduire sa propre empreinte numérique

PRÉREQUIS

- Disciplines de collecte (recommandé)
- Bonne pratique de l'informatique (navigateur, fichiers, tableur)

SOMMAIRE

01 Introduction au cyberespionnage

02 OSINT avancé

03 Analyse des empreintes numériques

04 Métadonnées et investigation numérique

05 Mise en situation : rapport d'exposition pour un client

06 Atelier pratique

CHAPITRE 01

Introduction au cyberespionnage

Acteurs, objectifs et chaîne d'attaque.

LEÇON Comprendre le cyberespionnage

Le cyberespionnage désigne l'accès non autorisé à des systèmes d'information pour y dérober des données, de façon discrète et souvent prolongée. Il se distingue du cybercrime (motivation financière directe) et du sabotage (destruction), même si les frontières sont poreuses.

Les acteurs

- Groupes liés à des États, souvent désignés par les éditeurs de sécurité sous le terme **APT** (**Advanced Persistent Threat**) ;
- Mercenaires numériques et sociétés de surveillance commerciale ;
- Groupes criminels revendant des accès.

La chaîne d'attaque (modèle conceptuel)

1. Reconnaissance (souvent en sources ouvertes) ;
2. Accès initial (hameçonnage ciblé, identifiants volés) ;
3. Installation et persistance ;
4. Mouvement latéral ;
5. Exfiltration.

Connaître cette chaîne sert à **placer des défenses à chaque étape** : moins d'informations exposées publiquement, authentification forte, détection des comportements anormaux, segmentation des réseaux, surveillance des flux sortants.

> Le cadre de référence MITRE ATT&CK, librement consultable, décrit de façon structurée les tactiques et techniques observées. Il est utilisé ici comme langage commun de défense.

LEÇON

Approfondissement : le paysage cyber africain

La transformation numérique rapide du continent s'accompagne d'une croissance des menaces. Les rapports publics d'organisations comme INTERPOL (évaluations des cybermenaces en Afrique) soulignent notamment :

- les escroqueries en ligne et la compromission de messageries professionnelles ;
- les rançongiciels visant entreprises et administrations ;
- les fraudes liées au paiement mobile ;
- les campagnes d'hameçonnage ciblant les clients bancaires.

Les réponses institutionnelles

- Création d'équipes nationales de réponse aux incidents (CERT/CSIRT) dans de nombreux pays ;
- Adoption de lois sur la cybercriminalité et la protection des données ;
- La Convention de Malabo (Union africaine, 2014) est entrée en vigueur en 2023 après avoir atteint le nombre requis de ratifications.

> **Points clés**
>
> - La fraude financière domine les menaces signalées.
> - Les CERT nationaux sont des interlocuteurs clés.
> - Le cadre juridique continental se consolide.

CHAPITRE 02

OSINT avancé

Opérateurs, pivots et hygiène de l'enquêteur.

LEÇON Techniques de recherche avancées

L'OSINT avancé se caractérise par la précision des requêtes, la capacité à **pivoter** d'un indice à l'autre et une rigoureuse hygiène opérationnelle.

Opérateurs de recherche

Opérateur	Usage	Exemple
`site:`	Limiter à un domaine	`site:gouv.sn rapport annuel`
`filetype:`	Type de document	`filetype:pdf budget santé 2025`
`"…"`	Expression exacte	`"appel d'offres" "fibre optique"`
`-`	Exclure un terme	`jaguar -voiture`

Le pivot

Un indicateur en révèle d'autres : un nom de domaine mène à son historique d'enregistrement public, à ses certificats TLS (journaux de transparence), aux autres sites hébergés sur la même infrastructure. Chaque pivot est noté dans un journal d'enquête.

Hygiène de l'enquêteur

- Environnement de travail dédié et séparé de ses comptes personnels ;
- Aucune interaction avec les cibles (pas de « like », pas de message, pas de demande d'ami) ;
- Respect des conditions d'utilisation des plateformes ;
- Collecte minimale de données personnelles.

LEÇON Approfondissement : documenter une enquête ouverte

Le **Protocole de Berkeley** sur les enquêtes numériques en sources ouvertes (publié en 2020 par le Human Rights Center de l'Université de Californie à Berkeley et le Haut-Commissariat des Nations unies aux droits de l'homme) fixe des standards professionnels pour la collecte, la préservation et la vérification d'informations en ligne.

Principes retenus

- **Exactitude** et **impartialité** ;
- **Préservation** des contenus avec métadonnées et empreintes ;
- **Sécurité** de l'enquêteur et des personnes concernées ;
- **Légalité** et respect de la vie privée ;
- **Documentation** complète de la méthodologie.

Journal d'enquête type

```
Date/heure UTC | Requête / URL | Résultat | Capture (fichier, SHA-256) | Commentaire
```

Points clés

- Un standard international existe : s'y référer.
- Tout ce qui n'est pas documenté n'existe pas.
- La sécurité de l'enquêteur fait partie de la méthode.

CHAPITRE 03

Analyse des empreintes numériques

Ce qu'une organisation expose, et comment le réduire.

LEÇON Empreinte numérique organisationnelle

L'empreinte numérique d'une organisation est l'ensemble des traces publiquement observables : sites, sous-domaines, adresses e-mail, profils des employés, documents publiés, dépôts de code, offres d'emploi détaillant les technologies utilisées…

Pourquoi l'analyser ?

Un attaquant commence par là. L'analyser **pour sa propre organisation** (ou pour un client qui l'a mandaté par écrit) permet de réduire la surface d'attaque.

Grille d'audit d'exposition

- **Domaines et sous-domaines** : services oubliés, environnements de test exposés ;
- **Documents publics** : métadonnées révélant noms d'utilisateurs, versions logicielles ;
- **Personnes** : organigramme reconstituable, formats d'adresses e-mail ;
- **Fuites** : identifiants apparus dans des fuites publiques connues (à vérifier via des services de notification légitimes).

> Un audit d'exposition sur une organisation tierce nécessite un **mandat écrit**. Sans autorisation, même une collecte « passive » peut poser problème juridiquement et déontologiquement.

LEÇON Approfondissement : réduire l'empreinte de son organisation

Après l'audit vient la **remédiation**. Les mesures les plus efficaces sont souvent simples.

Exposition constatée	Mesure
Sous-domaine de test accessible	Désactiver ou protéger par authentification

Exposition constatée	Mesure
Métadonnées dans les PDF publiés	Nettoyage systématique avant publication
Organigramme détaillé en ligne	Publier des fonctions génériques et des adresses de service
Identifiants dans des fuites	Réinitialisation, authentification multifacteur
Technologies détaillées dans les offres d'emploi	Formulations plus générales

Ajoutez un fichier `security.txt` (norme RFC 9116) sur votre site pour indiquer comment signaler une vulnérabilité.

Points clés

- Prioriser les expositions les plus exploitables.
- Automatiser le nettoyage des documents.
- Répéter l'audit périodiquement.

CHAPITRE 04

Métadonnées et investigation numérique

Lire les données cachées des fichiers.

LEÇON Exploiter les métadonnées

Les métadonnées sont des « données sur les données » : auteur d'un document, logiciel utilisé, dates de création et de modification, modèle d'appareil photo, parfois coordonnées GPS.

Types courants

Format	Métadonnées typiques
Photo (EXIF)	Appareil, date, réglages, éventuellement GPS
PDF	Auteur, créateur, producteur, dates
Bureautique	Auteur, dernier modificateur, révisions, commentaires

Précautions d'interprétation

- Les métadonnées peuvent être **absentes** (supprimées par les réseaux sociaux) ou **falsifiées** ;
- L'horloge d'un appareil peut être mal réglée ;
- Une métadonnée est un indice, jamais une preuve isolée.

Préservation de la preuve

Dans un cadre d'enquête autorisée, on travaille sur une **copie**, on calcule l'**empreinte cryptographique** (SHA-256) de l'original et on consigne chaque manipulation (chaîne de traçabilité).

> **Réflexe défensif :** nettoyez les métadonnées des documents que votre organisation publie.

LEÇON Approfondissement : nettoyer les métadonnées avant publication

Le réflexe défensif le plus rentable : **supprimer les métadonnées** des fichiers que l'on diffuse.

Procédure recommandée

1. Exporter le document final en PDF depuis le logiciel de traitement de texte, en désactivant l'inclusion des propriétés personnelles ;
2. Vérifier les propriétés du PDF (auteur, créateur, logiciel) ;
3. Pour les photos, supprimer les données EXIF (notamment la géolocalisation) ou désactiver la géolocalisation de l'appareil ;
4. Contrôler un échantillon avant chaque campagne de publication.

Des outils libres comme ExifTool permettent d'afficher et de supprimer les métadonnées de nombreux formats.

> **Points clés**
>
> - Les photos de smartphones contiennent souvent des coordonnées GPS.
> - Les documents bureautiques peuvent conserver des commentaires et révisions.
> - Intégrer le nettoyage à la procédure de publication.

CHAPITRE 05

Mise en situation : rapport d'exposition pour un client

Conduire un audit d'exposition mandaté sur données synthétiques et le restituer.

EXERCICE PRATIQUE Simulation guidée : audit « Kilimanjaro Logistics » complet

> **Scénario entièrement fictif.** Pays, organisations, personnes et données sont imaginaires et ne décrivent aucune situation réelle.

Vous disposez d'un **mandat écrit** (fictif) de la société « Kilimanjaro Logistics » pour évaluer son exposition publique. Les données suivantes sont synthétiques :

```
Sous-domaines : www, mail, vpn, test-erp, old-portal, dev
Certificats récents : erp-preprod.kilimanjaro-logistics.example
Document public : Rapport_annuel.pdf  (Auteur: j.mwangi ; Producteur: Office 2013)
Offre d'emploi : « administrateur système Windows Server 2012, VPN FortiGate »
Profils publics : 14 employés, format d'adresse prenom.nom@…
```

Consignes

1. Classez les expositions en critique / importante / mineure en justifiant.
2. Expliquez, pour les trois plus graves, comment un attaquant pourrait les exploiter (sans détail technique offensif).
3. Proposez une remédiation par exposition, avec responsable et délai.
4. Rédigez un résumé exécutif d'une demi-page pour la direction, sans jargon.

Barème indicatif (auto-évaluation sur 20)

Critère	Points
Classement argumenté	5
Compréhension des risques	4

Critère	Points
Remédiations concrètes	6
Résumé exécutif accessible	5

ÉTUDE DE CAS Étude de cas : la photo du bureau

> **Scénario entièrement fictif.** Pays, organisations, personnes et données sont imaginaires et ne décrivent aucune situation réelle.

Pour célébrer un contrat, le service communication d'une agence publique publie une photo de l'équipe dans son bureau. En arrière-plan, un tableau blanc affiche des noms de serveurs et un post-it porte un mot de passe Wi-Fi.

1. Quelles informations un tiers peut-il tirer de la photo ?
2. Quelles actions immédiates après la publication ?
3. Quelle règle intégrer à la procédure de publication des contenus visuels ?

LEÇON Fiche méthode : structure d'un rapport d'exposition

1. **Mandat et périmètre** (référence du mandat écrit, exclusions)
2. **Résumé exécutif** (risques principaux, actions prioritaires)
3. **Méthodologie** (sources ouvertes consultées, dates)
4. **Constats** (tableau : exposition, gravité, preuve archivée)
5. **Recommandations** (responsable, délai, coût)
6. **Annexes** (journal d'enquête, empreintes des fichiers)
7. **Destruction des données** collectées à la clôture

> **Points clés**
>
> - Le rapport lui-même est confidentiel : marquage et diffusion restreinte.
> - Aucune donnée personnelle superflue.

CHAPITRE 06

Atelier pratique

Laboratoire sur données synthétiques.

EXERCICE PRATIQUE Exercice : audit d'exposition d'une organisation fictive

Environnement : dossier de données synthétiques « Kilimanjaro Logistics » (organisation fictive) : liste de sous-domaines, trois documents PDF, cinq profils professionnels fictifs, une offre d'emploi.

1. Recensez toutes les informations exploitables par un attaquant.
2. Déduisez le format probable des adresses e-mail.
3. Identifiez les métadonnées sensibles des documents.
4. Classez les expositions par gravité.
5. Rédigez cinq recommandations de réduction de l'exposition.

> Toutes les données sont fictives. Ne transposez jamais l'exercice sur une organisation réelle sans mandat écrit.

ÉTUDE DE CAS Étude de cas : le document trop bavard

Scénario pédagogique (fictif). Un ministère publie en ligne un rapport PDF. Ses métadonnées révèlent le nom d'utilisateur réseau de l'auteur, la version d'un logiciel obsolète et le chemin d'un serveur interne. Quelques semaines plus tard, une campagne d'hameçonnage très ciblée vise précisément ce service.

1. Quelles informations ont pu servir à la reconnaissance ?
2. Quelle procédure de publication aurait évité la fuite ?
3. Comment sensibiliser les équipes de communication ?

LEÇON Glossaire de la formation

Les notions essentielles de la formation, à maîtriser pour l'examen final.

APT

Menace persistante avancée : groupe sophistiqué et durable.

Chaîne d'attaque

Étapes successives d'une intrusion, de la reconnaissance à l'exfiltration.

Chaîne de traçabilité

Documentation de toutes les manipulations d'une preuve.

EXIF

Format de métadonnées des photographies.

Empreinte cryptographique

Valeur (ex. SHA-256) garantissant l'intégrité d'un fichier.

Empreinte numérique

Ensemble des traces publiquement observables.

Métadonnées

Données décrivant un fichier (auteur, date, appareil, GPS…).

Pivot

Passage d'un indicateur à d'autres indicateurs liés.

security.txt

Fichier normalisé (RFC 9116) indiquant comment signaler une vulnérabilité.

LEÇON Pour aller plus loin : bibliographie et ressources

Sélection d'ouvrages, de normes et de ressources reconnues pour prolonger la formation. Les ressources en accès libre sont signalées.

- Haut-Commissariat des Nations unies aux droits de l'homme et Human Rights Center (UC Berkeley), **Protocole de Berkeley sur les enquêtes numériques en sources ouvertes**, 2022 (accès libre).
  Standards professionnels de l'OSINT.

- MITRE ATT&CK — base de connaissances des tactiques et techniques (attack.mitre.org).
  Langage commun de la défense.
- Hutchins, Eric M., Cloppert, Michael J. et Amin, Rohan M., « Intelligence-Driven Computer Network Defense Informed by Analysis of Adversary Campaigns and Intrusion Kill Chains », Lockheed Martin, 2011.
  Article fondateur de la chaîne d'attaque.
- IETF, RFC 9116, **A File Format to Aid in Security Vulnerability Disclosure**, 2022.
  Norme security.txt.
- Union africaine, **Convention sur la cybersécurité et la protection des données à caractère personnel** (Convention de Malabo), 2014, en vigueur depuis 2023.
  Cadre continental de la protection des données.

Ces références sont indiquées à titre pédagogique ; AFRICA'SPY n'a aucun lien d'affiliation avec leurs auteurs ou éditeurs.